

Verris — audyt parytetu funkcji wobec rynku

Data: 20 sierpnia 2026 · **Konwencja:** audyt zewnętrzny z passem adversaryjnym · **Zakres:** 352 pozycje funkcjonalne w 19 kategoriach

Rekomendacja: NO-GO na start. Nie z powodu luk funkcjonalnych — te są zwykłe i domykalne. Powodem jest sześć ustaleń, które wyszły dopiero w passie adversaryjnym: **klent płaący portfelem nie dostaje żadnej faktury, dowolne konto może zamówić hosting za 0 zł, formularz migracji pozwala wykonać polecenie jako root na węźle, subkonto może wydawać środki właściciela, błąd w obsłudze webhooka gubi wpłatę bezpowrotnie, i dodatek można obciążyć dziesięć razy pod rząd.** Żadnego z nich nie widać z poziomu dokumentacji ani listy funkcji.

Realistyczny termin startu: **6-8 tygodni**, przy czym cztery z sześciu pozycji krytycznych to praca na jeden-dwa dni każda.

1. Jak został przeprowadzony ten audyt

Standardowa analiza konkurencji przechyla wynik w dwie strony jednocześnie: konkurencję opisuje z materiałów marketingowych (wychodzi lepsza niż jest), a własny produkt z dokumentacji własnej (wychodzi lepszy niż jest — i to jest droższy błąd). Ten audyt eliminuje oba przechyły mechanicznie.

Dowód po stronie konkurencji pochodzi z dokumentacji producenta (docs.cpanel.net , docs.plesk.com , docs.directadmin.com) i baz wiedzy operatorów. Porównywarki hostingów są finansowane afiliacyjnie i były traktowane jak reklama — informacja pochodząca wyłącznie z nich jest oznaczona jako b.d. , nigdy jako TAK.

Dowód po stronie Verrisa pochodzi z kodu, nie z dokumentów projektu. Metoda: trasa → komponent → wywołanie API → kontroler → serwis → zasób. Pozycja dostaje status DZIAŁA dopiero wtedy, gdy ten łańcuch domyka się na realnym zasobie. Wykonano też automatyczny diff wszystkich tras API przeciwko wszystkim wywołaniom z trzech paneli — obie różnice symetryczne trafiły do wyniku.

Werdykt parytetu liczony jest wobec mediany pięciu hostingów polskich, nie wobec sumy możliwości cPanela, Pleska i DirectAdmina. Żaden hosting na rynku nie wystawia klientowi pełnej powierzchni cPanela, więc porównywanie się do niej produkuje listę luk, których nikt nie zamknął.

Pass adversaryjny — dlaczego bez niego ten dokument byłby wart mniej

Po pierwszym przejściu wynik brzmiał: 345 pozycji, 66 przewag, 27 blokerów. Następnie każde twierdzenie o **przewadze** zostało poddane próbie obalenia, a klasyfikacja **blokerów** zakwestionowana w obie strony — fałszywe alarmy i pozycje przeoczone. Wynik tej konfrontacji:

co się zmieniło	ile
twierdzeń o przewadze obalonych lub osłabionych	11 z 66
blokerów zdegradowanych po konfrontacji z definicją	16 z 27
nowych pozycji krytycznych, których pierwsze przejście nie zauważyło	7 (kategoria Z)
dowodów, które okazały się fałszywe i zostały poprawione	2

Te dwa fałszywe dowody wypisuję jawnie, bo to jedyny uczciwy sposób pokazania, ile warte jest pierwsze przejście: audyt twierdził „brak audytu dostępności w repo” — audyt istnieje (docs/legal/EAA_AUDYT_DOSTEPNOSCI_2026-07-07.md , z naprawionym skip-linkiem i focus-visible). I twierdził „brak trackera DPA” — tracker istnieje (docs/legal/dpa-subprocessors-tracking.md), choć jego treść potwierdza, że żadne DPA nie jest podpisane.

Skala dowodu

poziom	znaczenie	stan Verris
D0	zapisane w dokumencie	—
D1	istnieje kod	większość produktu
D2	test przechodzi w CI	0% — patrz §4.1
D3	zaobserwowane na produkcji	brak danych
D4	powtarzalna procedura z właścicielem i datą	brak dla backupów

2. Sześć rzeczy, które zatrzymują start

To są ustalenia z passu adversaryjnego. Każde zweryfikowałem osobiście w kodzie po zgłoszeniu.

Z-01 · Klient płaący portfelem nie dostaje faktury

Faktura powstaje w jednym miejscu — invoices.service.ts:192 — i to miejsce jest osiągalne wyłącznie z upsertFromStripe,wołanego tylko przy zdarzeniach invoice.* ze Stripe (billing.service.ts:702,787). Doładowanie portfela idzie przez stripe.client.ts:307 w trybie mode=payment **bez** invoice_creation, więc Stripe takiego zdarzenia nie emituje.

Wszystkie obciążenia portfela — pierwsza opłata za usługę (subscriptions.service.ts:1208), odnowienie (renewal.scheduler.ts:174), autoskalowanie (autoscaling-billing.service.ts:145), dodatki (addon.service.ts:105), domeny — **nie wołają InvoicesService w ogóle**. A invoices.admin.controller.ts ma same metody @Get, więc operator nie wystawi faktury ręcznie.

Klient płaci realnie (doładowanie do 10 000 zł, billing.service.ts:342) i nie dostaje żadnego dokumentu księgowego. **Nie ma na to obejścia w**

systemie. To poważniejsze niż brak faktur korygujących — te dotyczą dokumentów, których w ogóle się nie wystawia.

Z-02 • Dowolne konto może zamówić hosting za 0 zł

`POST /subscriptions` jest chroniony wyłącznie przez `JwtAuthGuard` (`subscriptions.controller.ts:29-30`), bez `@Roles`. DTO przyjmuje `paymentSource` przez `@IsEnum` (`dto/subscription.dto.ts:48`), a enum zawiera `MANUAL`. Serwis obsługuje tę wartość w `subscriptions.service.ts:361` i kieruje do `provisionWithoutCharge` (`:1271`), który ustawia usługę jako `ACTIVE` z okresem `+1` — bez obciążenia i bez faktury.

Własny komentarz w kodzie (`:81-82`) mówi wprost, że to ścieżka operatorska („comp accounts, bug bounties”). UI też ją tak opisuje („Ręczna (operator”). Została po prostu wystawiona na endpoint klienta. Ta sama luka jest zamknięta przy zmianie planu (`plan-change.service.ts:206-213`) — przy zakupie nie. Do tego brak rate-limitu na `POST /subscriptions`.

Efekt: konto założone w minutę zamawia nieograniczoną liczbę aktywnych usług za darmo, zapełnia węzły i wywraca rozliczenia.

Z-03 • Formularz migracji pozwala wykonać polecenie jako root na węźle

`ops/scripts/node-migration-worker.sh:250` i `:253` używają `eval` z interpolacją `${db}`, gdzie `db` to `source.database` podana przez klienta. Linia `:217` przekazuje `${spath}` (`source.remotePath`) do `lftp -e`, a `lftp` ma własny escape do powłoki. Walidacja w DTO to wyłącznie długość: `remotePath` ma `@MaxLength(1024)` (`dto/migration.dto.ts:88-89`), `database` ma `@MaxLength(64)` (`:108-109`) — **żadnego ograniczenia znaków**. `protocol` nie ma `@IsIn` (`:95-96`), więc można wymusić ścieżkę `ftp` z pominięciem `rsync`. Wartości lecą do skryptu bez zmian (`migration-orchestrator.service.ts:643,1277`), a skrypt działa jako **root**.

Jeden klient przejmuje węzeł i wszystkie konta pozostałych klientów na nim. Utrata i wyciek danych wszystkich najemców, plus naruszenie art. 32 RODO.

Ta sama klasa błędu występuje w `node-wp-install.sh:132` (tytuł strony) i `node-app-install.sh:46,64` (hasło administratora, przyjmowane surowym `@Body()` bez DTO). Tam wykonanie następuje jako użytkownik DA klienta, więc nie ma przekroczenia granicy najemcy — ale warto załatać jednym przebiegiem.

Z-04 • Subkonto może wydawać środki właściciela

`customer-permissions.guard.ts:75` — funkcja wyznaczająca wymagane uprawnienia kończy się `return []`, co oznacza **zezwoł**, dla każdej trasy, której nie trafi lista podciągów. Trasy `addons/*` i `vps` nie pasują do żadnej gałęzi. Obie zdejmują środki z portfela (`addon.service.ts:105`, `vps.service.ts:174`), a portfel jest właściciela, bo `jwt.strategy.ts:94` ustawia `userId = customerOwnerId ?? id`.

Subkonto zaproszone wyłącznie z uprawnieniem `TICKETS_READ` przechodzi. Guard musi domyślnie odmawiać, nie zezwalać — to jednolinijkowa zmiana z konsekwencją dla całej przyszłej powierzchni API.

Z-05 • Błąd w obsłudze webhooka gubi wpłatę bezpowrotnie

`billing.service.ts:444-453` zapisuje wiersz `stripeWebhookEvent` **przed** uruchomieniem handlera (`:455`), poza transakcją i bez cofnięcia przy wyjątku. Jeżeli `handleCheckoutCompleted` rzuci, Stripe ponawia dostawę — a ponowienie trafia w `:448-451` i dostaje `duplicate: true`. Uznanie portfela (`:523`) nigdy nie następuje.

Klient zapłacił, saldo się nie pojawiło, system uważa zdarzenie za obsłużone i odrzuca kolejne próby. Odzysk wyłącznie ręcznie w bazie — nie ma endpointu do ponownego przetworzenia.

Z-06 • Dodatek można obciążyć dziesięć razy pod rząd

`addon.service.ts:110` buduje `idempotencyKey` zawierający `Date.now()`. Każde wywołanie ma inny klucz, więc mechanizm ochrony przed podwójnym obciążeniem (`wallet-ledger.service.ts:94-105`) nigdy się nie uruchamia. Limit żądań dopuszcza 10 wywołań na godzinę (`addon.controller.ts:17`).

Podwójne kliknięcie, ponowienie przeglądarki albo timeout = do dziesięciu obciążeń za ten sam dodatek. Bez ścieżki zwrotu, bo nie ma ani refundu, ani faktury korygującej.

Pozostałe blokery (potwierdzone po degradacji)

ID	pozycja	dłaczego zostaje
H-20	test odtworzeniowy z datą wykonania	runbook wymaga drill'a przed LIVE (<code>OFFSITE_RESTORE_RUNBOOK.md:37-40</code>); w repo nie ma śladu, że go wykonano. Backupy i DR wymagają poziomu D4
M-06	faktura korygująca	zero wystąpień korekty w kodzie i schemacie; <code>fa3.xml.builder.ts:177</code> zawsze wpisuje <code><RodzajFaktury>VAT</code>
M-16	tryb offline KSeF	<code>KsefStatus.OFFLINE</code> istnieje w enumie (<code>schema.prisma:1432</code>) i nigdy nie jest ustawiany — awaria KSeF zostawia fakturę w PENDING bez kodu QR
M-17	walidacja XSD FA(3)	XML składany stringowo; komentarz <code>ksef-v2.client.ts:61-62</code> sam wskazuje, że smoke na <code>api-test</code> MF nie został wykonany
P-15	podpisane DPA z subprocesorami	tracker istnieje, ale wszystkie pozycje mają status „do podpisania”; kolumna Data pusta

3. Co pass adversaryjny odjął — degradacje

Uczciwość działa w obie strony. Szesnaście pozycji z pierwotnej listy blokerów nie spełnia definicji i zostało zdegradowanych. Najistotniejsze:

Odtworzenie na inny węzeł (H-16, H-17) — nie jest blokerem. Pierwsze przejście twierdziło, że ścieżki nie ma. Jest: `ops/docs/OFFSITE_RESTORE_RUNBOOK.md` zawiera sekcję „Scenariusz «utrata węzła»” z konkretnymi poleceniami — `node-account-restore.sh` `restore` na

nowym węźle. To nie jest funkcja produktu (runbook sam nazywa self-service „kolejnym, wydzielonym krokiem”), ale warunek „utrata danych **bez ścieżki odtworzenia**” nie jest spełniony. Zostaje WYSOKA — z tym, że blokerem pozostaje H-20, bo procedura nigdy nie została przetestowana.

Zawieszenie usługi przez operatora (A-25, A-26) — nie jest blokerem. Endpointy działają i są osiągalne poza UI. Warunek to „brak możliwości zatrzymania szkody”, a możliwość jest — brakuje wygody.

Brak CI (X-01 – X-08) — nie jest blokerem. Nie powoduje utraty danych, nie łamie prawa, nie blokuje dokumentu księgowego, nie odbiera możliwości zatrzymania szkody. Zostaje pozycją numer jeden do zrobienia, ale z innego powodu: bez CI naprawy sześciu pozycji krytycznych nie mają jak być potwierdzone. I warto zauważyć zależność — Z-02 i Z-04 to dokładnie te luki, które test guardu by wyłapał.

Rejestr czynności przetwarzania (P-11) i dostępność (P-12) — nie są blokerami. Oba dokumenty istnieją i są porządne. Art. 30 RODO wymaga formy pisemnej lub elektronicznej, nie modułu w produkcie. Audyt EAA został wykonany 7 lipca z naprawami w commicie; dokument powołuje się na zwolnienie mikroprzedsiębiorcy (art. 4 ust. 2 ustawy z 26.04.2024) — to warto potwierdzić z prawnikiem i pilnować progów 10 osób / 2 mln EUR, ale obowiązek na starcie nie powstaje.

Kolejka abuse (N-13) — nie jest blokerem. Powierzchnia częściowo istnieje: cordon wysyłki (outbound-cordon.admin.controller.ts:25,31), uprawnienie ABUSE_MANAGE, zarezerwowany adres abuse@, throttling na węźle. Brakuje kolejki i procesu, nie możliwości zatrzymania szkody.

4. Ustalenia strukturalne

4.1. CI nie istnieje — dowód D2 wynosi zero dla całego produktu

Katalog .github nie istnieje. Nie ma .gitlab-ci.yml, Jenkinsfile, .circleci ani .husky. Skrypt wdrożeniowy nie wywołuje npm test — health-gate po wdrożeniu sprawdza /health, nie testy.

W repozytorium jest 36 plików testowych i nikt ich nie uruchamia automatycznie. Kilka jest naprawdę dobrych: prorata zmiany planu (7 przypadków, cross-interval), kredyty SLA (15 przypadków wobec progów \$15), weryfikacja podpisu webhooka Stripe, budowa XML FA(3) (13 przypadków). Ta praca jest niewidoczna dla procesu.

Trzy zastrzeżenia do tego, co jest:

- Wszystkie 36 to testy jednostkowe z ręcznie pisanymi atrapami. @nestjs/testing i supertest nie występują nawet w devDependencies. Żaden test nie dotyczy Prismy, Postgresa, HTTP ani kontenera DI.
- Trzy pliki testujące RBAC czytają Reflect.getMetadata(ROLES_KEY) — weryfikują, że dekorator napisano, nie że guard blokuje. Ustalenie Z-04 pokazuje dokładnie, ile to jest warte.
- Jedyny test panelu klienta nie ma czym się uruchomić (brak skryptu test w apps/client-panel/package.json:5-11). Panele admina i staff nie mają ani jednego testu.

Obszary z zerowym pokryciem, w kolejności ryzyka: **moduł auth w całości, klient KSeF** (487 linii kryptografii rozmawiającej z API skarbowym), **ścieżka backup/restore, RenewalScheduler** (ścieżka, która sama wyłącza usługę klientowi), **account-deletion.service.ts** (operacja nieodwracalna), **directadmin.service.ts** (3057 linii, testowany jeden helper).

4.2. Funkcje-widma: 30 pozycji, gdzie kod i interfejs się rozjechały

UI bez endpointu (16). Najgroźniejszy przypadek to panel użytkowników MySQL — cztery operacje w UI (DbUsers.tsx:61,76,88,39), logika gotowa (directadmin.service.ts:1885-1945), kontroler nie istnieje. Każde kliknięcie kończy się 404. Podobnie PHP per domena i auto-logowanie do phpMyAdmin oraz webmaila.

Auto-logowanie ma **cichy fallback**: użytkownik widzi „Auto-logowanie niedostępne” (DatabasesTab.tsx:65) i uznaje to za chwilową awarię. Ten wzorzec nie zostawia śladu w logach i nie generuje zgłoszeń — nikt się nie dowie.

Backend bez UI (14). Tania do odzyskania grupa: ręczne zawieszenie i odwieszenie usługi, odtworzenie konta przez operatora, pobranie UPO, tworzenie incydentu na status page, zdjęcie cordonu wysyłki, odnowienie domeny przez klienta, eksport CSV portfela. Cały panel Product Ops / NOC jest read-only.

Komponenty osierocone. Kompletny edytor rekordów DNS i panel diagnostyki dostarczalności poczty nie są przez nic importowane. Endpointy pod nimi działają. **Kod wyłączony:** kreator stron WWW, 1612 linii zakomentowanych.

4.3. Backup — mechanizm dobry, potwierdzenia brak

Warstwa jest zbudowana porządnie: rclone sync do S3 z szyfrowaniem po stronie węzła, wersjonowanie, retencja 30 dni, timer systemd, raportowanie do control-plane, self-service listowania i pobierania, odtwarzanie z kopią bezpieczeństwa. Runbook DR istnieje i opisuje odtworzenie na nowym węźle.

Cztery rzeczy do poprawy, żadna nie jest brakiem funkcji:

- Nigdy nie przetestowano odtworzenia** (H-20, bloker). live-readiness.service.ts:171-180 sprawdza, czy backup się *wykonał* — nie czy da się z niego *odtworzyć*.
- Ostrzeżenie zamiast bramki** (H-19). Węzeł może przejść onboarding bez /etc/verris-backup.conf, dostając tylko wpis w logu. Kreator węzła nie ma kroku backupu.
- Kopia bezpieczeństwa przed odtworzeniem nie jest weryfikowana** (H-09). hosting-restore.service.ts:167 tylko kolejkuje zadanie w DA i nie czeka — destrukcyjne odtworzenie rusza mimo nieudanej kopii, a job dostaje COMPLETED w chwili przyjęcia zadania.
- Panel odtwarzania jest w zakładce „Usage”,** nie „Kopie zapasowe” (H-22). Klient w kryzysie tego nie znajdzie. Piętnaście minut pracy.

4.4. Rozliczenia i KSeF

Wystawianie faktur pierwotnych jest zrobione dobrze — numeracja VFV/RRRR/MM/NNNN z atomową sekwencją, numer nadawany dopiero przy opłaceniu,

snapshoty zgodne z art. 106e, PDF, upload, e-mail. Problem w tym, że **ta ścieżka uruchamia się tylko dla płatności kartą przez Stripe** (Z-01).

KSeF wygląda znacznie lepiej, niż zakładała notatka z 12 sierpnia. Moduł generuje **FA(3)** (crd.gov.pl/wzor/2025/06/25/13775/ , wariant 3, schemat 1-0E), rozmawia z **API v2**, ma pełny sześciokrokowy przepływ uwierzytelnienia tokenem, sesję online, poprawne szyfrowanie RSA-OAEP-SHA256 + AES-256-CBC, cron co 10 minut, obsługę 4xx/5xx i audyt każdego przejścia. Wcześniejsza notatka o FA(2)/KSeF 1.0 jest nieaktualna.

Dwa zastrzeżenia, których pierwsze przejście nie odnotowało: KSEF_ENABLED ma domyślnie '0', a KSEF_ENV domyślnie 'test' (platform-settings.keys.ts:136-137). Po włączeniu bez zmiany środowiska faktury pójdą na środowisko testowe MF.

Podobny problem ma **SLA**: sla-credit.scheduler.ts:79 kończy działanie natychmiast, gdy SLA_CREDITS_ENABLED jest wyłączone — a domyślnie jest. Regulamin obiecuje kredyty, kod ich nie nalicza, i **live-readiness nie ma checka SLA**, więc flaga może zostać wyłączona bez żadnego sygnału.

5. Gdzie Verris jest realnie lepszy od rynku

57 pozycji z werdyktem PRZEWAGA — po odjęciu jedenastu, które nie przeżyły passu adwersaryjnego.

Migracja jako produkt, nie jako usługa. Na rynku PL migrację robi dostawca ręcznie. U nas to samoobsługowy przepływ z wykrywaniem źródła, **delta-syncem przed przełączeniem**, planem i weryfikacją cutoveru. Delta-sync minimalizuje przestój — ręczna migracja tego nie potrafi. Zastrzeżenie: preflight dla SFTP testuje tylko baner portu (migration-preflight.service.ts:93-131), więc literówka w haśle przechodzi walidację. I patrz Z-03 — walidacja wejścia wymaga naprawy przed startem.

Bezpieczeństwo logowania powyżej standardu rynkowego. Passkeys/WebAuthn, lista aktywnych sesji ze zdalnym wylogowaniem, break-glass. Nikt na rynku PL nie ma passkeys. U nazwa.pl **2FA jest płatne** (~300 zł/rok) — gotowy argument. Zastrzeżenie: auto-wylogowanie po bezczynności kasuje tylko ciasteczko, JWT zostaje ważny do TTL — to timeout UI, nie kontrola bezpieczeństwa.

Autoskalowanie z limitem kosztu. Silnik z cronem co minutę, cap egzekwowany w silniku (z testem), kalkulator, historia zdarzeń. Tylko dhosting ma coś zbliżonego.

Analityka odwiedzin bez cookies. Własny tracker, snippet, retencja 90 dni. Nikt na rynku PL tego nie ma. Notatka projektowa ostrzegała, że ta funkcja była sprzedawana bez implementacji — **to ostrzeżenie jest nieaktualne**, implementacja istnieje.

Zgodność jako funkcja produktu. Eksport danych osobowych (ZIP z 12 sekcji z 13 tabel, TTL 7 dni), żądanie usunięcia konta z karencją i cofnięciem, ponowna akceptacja przy zmianie regulaminu, DPA na żądanie, retencja i anonimizacja logów. Rynek PL ma z tego ułamek — ale cały ten obszar ma zero testów, a account-deletion.service.ts wykonuje operację nieodwracalną.

Dodatkowo: publiczna strona statusu (tylko cyber_Folks i dhosting na rynku), staging WordPressa (tylko 2 z 5), IAM z subkontami (tylko home.pl ma coś podobnego), program eko i badge — których nie ma nikt.

Wniosek pozycjonujący. Przy 39 zł/mies. (468 zł/rok) jesteśmy powyżej wszystkich promocji rynkowych, ale **poniżej lub blisko cen odnowienia**: cyber_Folks 249 zł, dhosting 229 zł, nazwa.pl 450 zł, home.pl 679 zł. Skok cenowy po pierwszym roku wynosi u nich od x2 do x35 i jest najczęściej wytykanym grzechem branży. Jedyna sensowna narracja to **cena stała, bez skoku po roku** — i ona jest zgodna z prawdą.

Uwaga do materiałów sprzedażowych: dwie rzeczy, które wyglądały na przewagi, nie nadają się do komunikacji w obecnym stanie. „Weryfikacja własności domeny” to w rzeczywistości checklist konfiguracji — brak wyzwania TXT, więc dowolny użytkownik może dodać cudzą domenę i doprowadzić ją do statusu ACTIVE (A-16 , do naprawy niezależnie od komunikacji). A „SLA z kredytami” jest wyłączone flagą.

6. Luki, które klient zauważy w pierwszym tygodniu

Poza blokerami, w kolejności wg tego, jak szybko wygenerują zgłoszenie.

pozycja	dłaczego boli
Logi dostępu i błędów WWW (K-04 , K-05)	wszystkie 5 hostingów PL to ma; bez tego klient nie zdiagnozuje własnej strony i pisze do nas
Import/eksport bazy z panelu (D-12)	standard u wszystkich; dziś wymaga wyjścia do DirectAdmina
Użytkownicy MySQL — 4 operacje (D-04 – D-07)	UI jest, każde kliknięcie zwraca 404
Edytor DNS (F-01)	kompletny komponent istnieje i nie jest podpisany; klient trafia do obcego panelu i loguje się ręcznie, bo SSO też nie działa
Zmiana kwoty istniejącej skrzynki (E-05)	klient musi usunąć i odtworzyć skrzynkę
Zmiana hasła istniejącego konta FTP (C-18)	brak jakiegolwiek ścieżki edycji
SPF/DKIM/DMARC (E-15 – E-17)	backend w pełni działa, komponent osierocony; poczta bez tego trafia do spamu
Ponowienie płatności portfelem w karencji (Z-07)	klient doładowuje saldo i i tak zostaje zawieszony po 3 dniach
Edycja php.ini (B-05)	4 z 5 hostingów PL to ma
Redis / cache obiektowy (D-15 , J-03)	3 z 5 hostingów ma w cenie; realny wyróżnik dla WordPressa
Automatyczne aktualizacje WordPressa (I-04)	4 z 5 hostingów PL
Usunięcie zapisanej karty (M-26)	wymóg konsumencki, dziś niemożliwe
Katalog aplikacji: 2 pozycje (I-01)	Softaculous ma ~400; my mamy Nextcloud i PrestaShop

7. Plan zamknięcia

Dni 1-3 — zatrzymać krwawienie

Cztery z sześciu pozycji krytycznych to zmiany punktowe.

Z-02 — usunąć `MANUAL` z DTO endpointu klienta albo dodać `@Roles(ADMIN)` ; dodać `rate-limit` na `POST /subscriptions`. Z-04 — zmienić `return []` w `customer-permissions.guard.ts:75` na domyślną odmowę i wypisać jawnie trasy publiczne. Z-06 — usunąć `Date.now()` z klucza idempotencji dodatku. Z-03 — dodać `@Matches` na `database`, `remotePath` i `@IsIn` na `protocol`; w skryptach zastąpić `eval` bezpiecznym wywołaniem. Załatać przy okazji `node-wp-install.sh` i `node-app-install.sh`.

Równolegle: X-01-X-03 — `.github/workflows/ci.yml` z `pnpm typecheck && pnpm lint && pnpm test` i status wymagany do merge. Bez tego kolejne naprawy nie mają jak być potwierdzone.

Tygodnie 1-3 — rozliczenia

Z-01 — faktura dla każdej płatności, nie tylko dla Stripe. To zmiana architektoniczna: obciążenia portfela muszą przechodzić przez `InvoicesService`. Największa pozycja w całym planie. Z-05 — zapis zdarzenia webhooka w tej samej transakcji co handler, plus endpoint do ponownego przetworzenia. M-06 — faktury korygujące: model, relacja do faktury pierwotnej, `<RodzajFaktury>K0R` w FA(3), PDF. M-16 — tryb offline KSeF z kodem QR i dosyłaniem po powrocie usługi. M-17 — walidacja XSD i smoke na `api-test` MF z realnym tokenem. X-07 — testy klienta KSeF.

Tygodnie 3-5 — odtwarzalność i operacje

H-20 — wykonać drill odtworzeniowy zgodnie z runbookiem, zapisać datę, wynik i właściciela; dodać metrykę i alert. Dopiero to daje poziom D4. H-19 — twarda bramka na konfigurację backupu w onboardingu węzła. H-09 — czekać na potwierdzenie kopii bezpieczeństwa przed odtworzeniem; `COMPLETED` dopiero po realnym odtworzeniu. X-06, X-08 — testy modułu `auth` i ścieżki `restore`. A-16 — wyzwanie TXT przy weryfikacji domeny. N-16 — włączyć kredyty SLA i dodać check w live-readiness.

Tygodnie 4-6 — reszta

P-15 — podpisać DPA z Stripe, dostawcą VPS, dostawcą backupu off-site i OpenProviderem. N-13 — kolejka abuse: encja zgłoszenia, przypisanie do konta, akcje, termin, ślad audytowy. Odzyskanie funkcji-widm: podpięcie edytora DNS, panelu dostarczalności, użytkowników MySQL, PHP per domena, przycisków zawieszenia i `restore`'u w panelu operatora.

8. Zastrzeżenia do tego audytu

- **Nie sprawdzono niczego na produkcji.** Cały audyt operuje na poziomie D1. `DZIAŁA` znaczy „łańcuch wywołań domyka się w kodzie", nie „zadziało u klienta".
- **Sześć ustaleń krytycznych nie zostało wykorzystanych praktycznie.** Zweryfikowałem je w kodzie, ale nie napisałem eksploita ani nie odtworzyłem scenariusza. Przed naprawą warto potwierdzić każdy z nich testem, który najpierw czerwieni się na obecnym kodzie.
- **To nie zastępuje testów penetracyjnych.** Z-03 i Z-04 wyszły przy przeglądzie kodu pod kątem kilku znanych wzorców. Systematyczne badanie znalazłoby prawdopodobnie więcej.
- **Nie oceniono jakości UX ani wydajności.** Responsywność panelu (Q-09) jest twardym wymogiem z decyzji brandingowej i nie ma w repo dowodu na jej weryfikację.
- **Nie policzono unit economics.** Koszt węzła wobec 39 zł/mies. nadal nie jest policzony. Kilka luk (G-11 skaner malware, J-01 LiteSpeed, J-02 LSCache) to pozycje licencyjne, więc ich zamknięcie zmienia rachunek. To osobna praca i powinna poprzedzić potwierdzenie ceny.
- **Część danych rynkowych jest miękka.** Pozycje `b.d.` nie były publicznie potwierdzone. Informacje o retencji backupu, lokalizacji centrów danych i cenach migracji u niektórych operatorów pochodzą z niezależnych recenzji i wymagają potwierdzenia u źródła przed użyciem w materiałach porównawczych.
- **Nie użyto formuły „warunkowe GO".** Ta konstrukcja w czerwcu przepuściła start z otwartymi blokerami.

Źródła

Panele — dokumentacja producentów: [docs.cpanel.net](#) · [docs.plesk.com](#) · [docs.directadmin.com](#)

Rynek PL: [cyberfolks.pl](#) — parametry techniczne · [cyberfolks.pl](#) — regulamin SLA · [dhosting.pl/dpanel](#) · [dhosting.pl](#) — KSeF · [home.pl/hosting](#) · [pomoc.home.pl](#) · [nazwa.pl/hosting](#) · [seohost.pl/hosting](#) · [seohost.pl](#) — przywracanie kopii

Nowa fala: [docs.hostinger.com](#) · [hostinger.com/web-hosting](#)

Metoda: [phury/pm-skills](#) — [intended-vs-implemented](#) · [alirezarezvani/claude-skills](#) — [competitive-teardown](#) · [product-on-purpose/pm-skills](#) · [obra/superpowers](#) — [verification-before-completion](#)

Verris: repozytorium `ekohost`, stan na 2026-08-20.